

Email & Communications Policy

1. Purpose

This policy defines acceptable use of Summit IT Services electronic communication systems, including email, instant messaging, video conferencing, and collaboration tools. It establishes rules to protect company information, ensure professional communications, and defend against threats such as phishing, business email compromise (BEC), and data leakage.

2. Scope

This policy applies to:

- All Summit IT Services employees, contractors, and temporary staff.
- All electronic communication platforms provided by Summit IT Services: Microsoft 365 (Outlook, Exchange Online), Microsoft Teams, Slack, and Zoom.
- All communications sent from Summit IT Services accounts (@summitit.com) or on behalf of Summit IT Services.
- Archived and retained communications as defined in POL-011 (Data Backup & Retention Policy).

3. Policy Statements

3.1 Email Use Requirements

3.1.1 The Microsoft 365 / Exchange Online email system (@summitit.com) is the official and only approved email platform for business communications. Employees must not conduct official business correspondence from personal email accounts (Gmail, Yahoo, Hotmail, etc.).

3.1.2 Email is provided for business use. Limited personal use is permitted provided it does not violate any provision of POL-001 (Acceptable Use Policy) and is not related to personal business ventures.

3.1.3 Employees must not auto-forward company email to personal external email accounts. Auto-forwarding rules that send email to external addresses are technically blocked by Microsoft 365 Exchange transport rules. Any business need for email forwarding must be submitted via SummitDesk.

3.1.4 Distribution lists and shared mailboxes must be provisioned through SummitDesk, not created by individual employees in Outlook. Owners of distribution lists must review membership quarterly and remove departed employees.

3.1.5 Out-of-office messages for extended absences (5+ business days) must be configured and must not disclose detailed travel itineraries, security codes, or information that could be exploited by social engineers.

3.2 Secure Email Practices

3.2.1 Emails containing **Confidential** data must be encrypted using Microsoft Purview sensitivity labels before sending. Apply the "Confidential" label in Outlook, which automatically enforces encryption via Microsoft Purview Information Protection.

3.2.2 Emails containing **Restricted** data must carry the "Highly Confidential" Purview label and must not be sent externally without Legal and management approval. Prefer secure file sharing (SharePoint protected link) over email attachments for Restricted data.

3.2.3 Email attachments containing sensitive data must not be sent as unencrypted attachments to external parties. Use a Purview-protected SharePoint link or a verified secure file transfer mechanism.

3.2.4 Employees must not include password hints or credentials in email, even in encrypted email. Use 1Password secure share for credential sharing.

3.2.5 Company email accounts must be accessed only through: - Outlook desktop app (managed by Intune/Jamf) - Outlook Web App (OWA) at <https://outlook.office.com> (via Okta SSO, on a managed or compliant device) - Outlook mobile app (with Intune MAM enrolled per POL-004)

Native device mail apps (Apple Mail, Android Mail) must not be configured with company accounts.

3.3 Phishing and Malicious Email

3.3.1 Employees must be vigilant for phishing, spear-phishing, and business email compromise (BEC) attacks. Common indicators include:

Warning Sign	Example
Urgent payment or wire transfer request	"Wire \$50,000 immediately - CEO request"
Mismatched sender domain	Displayed name is "CEO" but address is <code>ceo@summ1t-it.com</code>
Unexpected credential prompts	Link asking for Okta login from an unusual URL
Requests to bypass normal process	"Don't involve Finance - just send me the invoice"
Unexpected attachments	Unsolicited <code>.zip</code> , <code>.docm</code> , <code>.iso</code> attachments

3.3.2 All suspicious emails must be reported using the **Report Phishing** button in Outlook (available on desktop and web). Alternatively, forward the email as an attachment to soc@summitit.com. Do not forward or re-share phishing emails in other channels.

3.3.3 Employees must not click links or open attachments in emails they suspect to be phishing. If unsure, contact the IT Service Desk at `#it-help` on Slack or servicedesk@summitit.com before clicking.

3.3.4 If an employee has clicked a phishing link or entered credentials into a suspicious page, they must: 1. Immediately call the IT Service Desk at +1 (800) 555-7866. 2. Change their Okta password. 3. Notify the SOC at soc@summitit.com.

3.3.5 Microsoft Defender for Office 365 scans all incoming email attachments and links. Emails that are quarantined can be reviewed in the Microsoft 365 security portal or by contacting the IT Service Desk.

3.4 Instant Messaging - Slack

3.4.1 **Slack** is the approved instant messaging platform for internal communication. Employees must use their @summitit.com Okta-connected Slack account. Personal Slack workspaces must not be used for company communications.

3.4.2 Slack is integrated with Okta for SSO and MFA. Employees must not use Slack desktop without completing Okta authentication.

3.4.3 Sensitive data handling in Slack: - **Internal** information may be shared in appropriate public or private Slack channels. - **Confidential** information should be avoided in Slack where possible; if necessary, use private channels with only the required members and mark clearly with [CONFIDENTIAL]. - **Restricted** information must not be shared in Slack under any circumstances. Use SharePoint secure links or encrypted email instead.

3.4.4 Slack DMs must not be used to share credentials, even temporarily. Use 1Password secure share.

3.4.5 External Slack Connect channels (connecting external organizations) must be reviewed and approved by IT Security before activation. Employees must not accept Slack Connect invitations from unknown organizations.

3.4.6 Slack message retention is governed by POL-011. Employees must not use Slack retention settings to delete messages that may be subject to a legal hold.

3.5 Video Conferencing - Zoom and Microsoft Teams

3.5.1 **Zoom** and **Microsoft Teams** are the approved video conferencing platforms. Both are integrated with Okta SSO.

3.5.2 All external meetings (with clients, vendors, or public attendees) must require a **meeting password or waiting room** to prevent unauthorized access. For large external calls or webinars, an IT Service Desk request should be made for assistance with security settings.

3.5.3 Employees hosting meetings must not share meeting links publicly (e.g., on social media) for calls involving confidential discussions.

3.5.4 Meeting recordings are permitted where all participants consent (confirm verbally or by in-meeting acknowledgment at start). In jurisdictions requiring two-party consent for recording, participants must be notified and given the opportunity to leave before recording starts.

3.5.5 Meeting recordings containing Confidential or Restricted information must be stored in restricted SharePoint folders with appropriate sensitivity labels applied after the call. Recordings must not be stored in personal cloud storage.

3.5.6 AI meeting transcription and note-taking tools (e.g., Otter.ai, Fireflies) must be approved by IT Security before use in any company meeting. Approved AI meeting tools are listed in the software catalog. See also POL-012 (Generative AI & AI Tools Usage Policy).

3.6 Prohibited Communications

The following are expressly prohibited using any Summit IT Services communication system:

- Harassment, discrimination, or threatening communications.
- Chain letters, pyramid schemes, or unauthorized mass mailings.
- Spam or unsolicited bulk email.
- Communicating proprietary information or trade secrets to unauthorized parties.
- Communications that misrepresent the sender's identity or affiliation.
- Political campaigning or solicitation unrelated to Summit IT Services business.

3.7 Monitoring and Privacy

3.7.1 All email and communications on company systems are the property of Summit IT Services and may be monitored, audited, or reviewed by IT Security, Legal, or HR as legally permitted.

3.7.2 Email content may be reviewed in the context of security investigations, legal proceedings, compliance audits, or HR investigations. Employees have no expectation of privacy in company communications.

3.7.3 Microsoft 365 eDiscovery and Compliance Center tools may be used to place holds on mailboxes and Slack exports in response to legal or HR matters, without prior notice to the employee.

4. Roles & Responsibilities

Role	Responsibility
All Employees	Use approved platforms; report phishing; follow secure email practices; comply with data handling requirements
IT Service Desk (L1)	Respond to phishing reports; assist with email issues; escalate security events to SOC
SOC	Investigate phishing reports; respond to BEC incidents; manage email security tools
IT Security & Compliance	Own policy; configure DLP and transport rules; conduct phishing simulations; manage eDiscovery
L3 Engineering	Maintain Exchange Online configuration; manage Slack and Zoom Okta integrations; configure Microsoft Defender for Office 365
Legal	Request legal holds; conduct eDiscovery; advise on recording consent laws
HR	Investigate communications policy violations; partner with IT on disciplinary matters

5. Enforcement & Consequences

5.1 Microsoft 365 transport rules, DLP policies, and Microsoft Defender for Office 365 enforce many technical controls automatically (blocking auto-forwarding, scanning attachments, encrypting labeled email).

5.2 Policy violations:

- **Failing to report phishing (first occurrence):** Phishing simulation training assigned.
- **Sending Confidential data without encryption:** Written warning; security training.
- **Auto-forwarding company email to personal account:** Immediate block; formal written warning; investigation of forwarded data.
- **Sharing Restricted data via Slack or unapproved tool:** HR investigation; access restriction; potential termination.
- **Harassment or prohibited communications:** HR investigation; disciplinary action up to termination; potential legal referral.

6. Exceptions

Exceptions (e.g., a business need to send external email through a third-party marketing platform) must be submitted via SummitDesk. Exceptions require IT Security review, Legal review (for data processing), and CISO approval.

7. Related Documents

- POL-001 - Acceptable Use Policy
- POL-005 - Data Classification & Handling Policy
- POL-007 - Software Installation & Licensing Policy
- POL-011 - Data Backup & Retention Policy
- POL-012 - Generative AI & AI Tools Usage Policy
- REF-0001 - Summit IT Environment Standards
- Microsoft 365 DLP Configuration (internal wiki)
- Phishing Incident Response Runbook (internal runbook)

8. Revision History

Version	Date	Author	Summary of Changes
1.0	2021-02-01	IT Security	Initial release
1.1	2022-05-15	IT Security	Added Slack and Zoom sections; introduced Purview label requirements for email

2.0	2024-07-01	IT Security & Compliance	Full rewrite; added AI transcription tools clause; updated phishing response procedure; added Slack Connect approval requirement
2.1	2025-12-05	IT Security & Compliance	Annual review; added two-party consent recording reminder; updated external meeting security requirements